

RISK ID	ASSETS AFFECTED	THREAT	VULNERABILITY	RISK DESCRIPTION	LIKELIHOOD (1 - 5)	IMPACT (1 - 5)	RISK SCORE	RISK RATING	ISO 27001 CONTROLL	POPIA REFERENCE	TREATMENT OPTION	PROPOSED CONTROL	RISK OWNER	RESIDUAL LIKELIHOOD	RESIDUAL IMPACT	RESIDUAL SCORE	RESIDUAL RATING	TARGET DATE	STATUS
RISK - 001	Patient Health Record System	Ransomware attack	No MFA, unpatched systems, untested backups	Ransomware encrypts the patient record database making all patient medical histories inaccessible during active consultations	5	5	FALSE	CRITICAL	A.8.7, A.8.13, A.8.5	Section 19 (Security Safeguards)	Mitigate	Enable MFA, deploy EDR solution, implement 3-2-1 backup strategy, test restoration monthly, patch management programme	IT Manager	2	4	8	MEDIUM	Month 2	Open
RISK - 002	Staff Laptops (35 devices)	Theft or loss of device	No full disk encryption enabled	Stolen laptop containing patient records results in automatic POPIA reportable breach with fines up to R10 million	4	5	TRUE	CRITICAL	A.8.24, A.7.9, A.8.1	Section 19, Section 22	Mitigate	Enable BitLocker on all Windows laptops, FileVault on Mac, enforce device registration, remote wipe capability via Intune	IT Manager	4	1	4	LOW	Month 1	Open
RISK - 003	Microsoft 365 Accounts	Phishing attack	No MFA, no security awareness training, no email filtering	Staff credentials compromised via phishing giving attacker access to patient referrals and medical correspondence in email	5	4	FALSE	CRITICAL	A.8.5, A.6.3, A.8.23	Section 19	Mitigate	Enable MFA on all accounts, deploy Microsoft Defender for Office 365, quarterly phishing simulations, annual awareness training for all 45 staff	IT Manager	3	2	6	MEDIUM	Month 1	Open
RISK - 004	Information Regulator Compliance	Regulatory enforcement action	No Information Officer appointed or registered as required by POPIA Section 55	Organisation cannot lawfully process personal information without a registered Information Officer exposing directors to criminal liability	5	4	FALSE	CRITICAL	A.5.2, A.5.31	Section 55, Section 56	Mitigate	Appoint senior staff member as Information Officer, register on Information Regulator portal, publish contact details, provide POPIA training to appointee	CEO	1	3	3	LOW	Month 1	Open
RISK - 005	All Systems	Data breach with no response plan	No incident response procedure, no breach notification process	In the event of a breach the organisation misses the mandatory 72 hour POPIA notification window to the Information Regulator	4	5	TRUE	CRITICAL	A.5.24, A.5.26, A.5.27	Section 22 (Notification of Security Compromises)	Mitigate	Develop Incident Response Plan, define breach notification procedure with 72 hour timeline, conduct tabletop exercise, train all staff on reporting	IT Manager	2	3	6	MEDIUM	Month 2	Open
RISK - 006	Patient Health Record System	Insider threat - unauthorised record access	No access logging, no role based access control, no access reviews	Clinical or admin staff view patient records of family members, colleagues or public figures with no legitimate clinical need	4	4	FALSE	HIGH	A.8.2, A.8.15, A.8.16	Section 19, Section 11 (Consent)	Mitigate	Implement role based access control, enable audit logging on record access, quarterly access reviews, break glass procedure, staff confidentiality agreements	IT Manager	2	4	8	MEDIUM	Month 3	Open
RISK - 007	Laboratory Integration API	Third party data breach	No vendor security assessment, no POPIA operator agreement	Partner pathology laboratory suffers a breach exposing MediCare Connect patient test results with joint liability under POPIA	3	5	TRUE	HIGH	A.5.19, A.5.20, A.5.21	Section 20, Section 21 (Operator obligations)	Mitigate	Conduct vendor security assessment, execute POPIA compliant Operator Agreement, require breach notification clause, annual vendor review	GRC Analyst	2	4	8	MEDIUM	Month 4	Open
RISK - 008	Network and Server Infrastructure	Load shedding power outage	No UPS on servers, no generator, no graceful shutdown procedure	Repeated Stage 6 load shedding causes abrupt server shutdown corrupting patient database and halting telehealth consultations	5	3	FALSE	HIGH	A.7.11, A.8.14, A.5.30	Section 19 (Availability)	Mitigate	Install UPS with 4 hour capacity, backup generator for server room, automated graceful shutdown scripts, migrate critical systems to cloud, Eskom schedule monitoring	IT Manager	5	1	5	LOW	Month 3	Open
RISK - 009	Backup Systems	Backup failure during recovery	Backups never tested, stored on site only, not encrypted	Following a ransomware attack or hardware failure the organisation discovers backups are corrupt or incomplete resulting in permanent loss of patient medical history	3	5	TRUE	HIGH	A.8.13, A.8.24, A.5.30	Section 19, National Health Act 16 year retention requirement)	Mitigate	Implement 3-2-1 backup strategy, encrypt all backups, store one copy offline in SA data centre, monthly restoration testing with documented evidence	IT Manager	1	4	4	LOW	Month 2	Open
RISK - 010	Email System	Misdirected patient information	No data loss prevention, no email encryption, no recipient verification	Staff send patient test results or medical reports to the wrong email recipient causing an unauthorised disclosure of special personal information	4	3	FALSE	HIGH	A.5.14, A.8.12, A.6.3	Section 19, Section 22	Mitigate	Deploy Microsoft Purview DLP policies, enable email encryption for patient data, implement recipient confirmation prompts, staff training on secure communication	IT Manager	2	3	6	MEDIUM	Month 3	Open
RISK - 011	Staff Accounts	Departing employee retains access	No formal offboarding process, no access revocation checklist	Former clinical staff retain active credentials to the Patient Health Record System after termination allowing continued access to patient data	4	3	FALSE	HIGH	A.6.5, A.8.2, A.5.11	Section 19	Mitigate	Formal offboarding checklist, HR to IT notification workflow, same day access revocation, asset return process, monthly orphan account audit	HR Manager	1	3	3	LOW	Month 2	Open
RISK - 012	Telehealth Platform	Unauthorised interception of consultation	Consultations conducted over unsecured home WIFI, no waiting room controls, recordings unmanaged	Patient telehealth consultation is intercepted or joined by an unauthorised party breaching doctor patient confidentiality under the National Health Act	3	4	TRUE	HIGH	A.8.20, A.8.24, A.5.14	Section 19, National Health Act Section 14 (Confidentiality)	Mitigate	Enforce meeting lobby and unique meeting IDs, require VPN for remote consultations, disable recording by default, staff guidance on private consultation environment	IT Manager	1	4	4	LOW	Month 3	Open
RISK - 013	Finance and Executive Accounts	SIM swap fraud	SMS based authentication used for banking and account recovery	Attacker executes SIM swap on Finance Manager mobile number intercepting OTPs to authorise fraudulent payments or reset business account credentials	3	4	TRUE	HIGH	A.8.5, A.5.17	Section 19	Mitigate	Replace SMS OTP with authenticator app or hardware token, register SIM swap alerts with mobile provider, dual authorisation for payments above R50,000	Finance Manager	1	4	4	LOW	Month 2	Open
RISK - 014	Physical Patient File Archive	Theft or unauthorised access to paper records	Filing room unlocked during business hours, no access log, no CCTV coverage	Historical paper patient files containing full medical histories are removed or photographed by an unauthorised person	3	4	TRUE	HIGH	A.7.1, A.7.2, A.7.3, A.7.7	Section 19	Mitigate	Install access controlled lock on filing room, maintain physical access register, install CCTV, implement clear desk policy, accelerate digitisation programme	Facilities Manager	1	4	4	LOW	Month 3	Open
RISK - 015	Appointment Booking Portal	Web application attack	No web application firewall, no penetration testing, unpatched portal software	Public facing booking portal is compromised via SQL injection exposing patient names, ID numbers and contact details	3	4	TRUE	HIGH	A.8.8, A.8.9, A.8.26, A.8.29	Section 19	Mitigate	Deploy web application firewall, annual penetration test, secure development requirements in vendor contract, vulnerability scanning programme	IT Manager	1	4	4	LOW	Month 4	Open
RISK - 016	All Devices and Systems	Malware infection via unpatched software	No patch management process, antivirus not deployed on all devices	Outdated operating systems and applications are exploited allowing malware to spread across the clinical network	4	3	FALSE	HIGH	A.8.7, A.8.8, A.8.19	Section 19	Mitigate	Deploy centrally managed antivirus to all 45 devices, monthly patch cycle, automated vulnerability scanning, remove local administrator rights	IT Manager	2	3	6	MEDIUM	Month 2	Open
RISK - 017	Network Connectivity	Fibre cable theft or vandalism	Single Internet provider, no failover connection	Theft of fibre infrastructure in the area cuts internet access halting telehealth consultations and cloud based record access	3	3	FALSE	MEDIUM	A.8.14, A.5.30, A.7.11	Section 19 (Availability)	Mitigate	Implement secondary LTE failover connection, document offline consultation procedure, local cached access to critical records	IT Manager	3	1	3	LOW	Month 4	Open